

REVISIÓN SISTEMÁTICA DE LITERATURA

Usable Security

Sección 4.4.2 — Ayudar a los desarrolladores de seguridad a mejorar la usabilidad

Di Nocera, Tempestini & Orsini · Information 2023, 14(12), 641

La disyuntiva de fondo

55

estudios seleccionados

Publicados entre 2005 y 2022, agrupados en cuatro clústeres temáticos.

7

artículos en la sección 4.4.2

Aunque el texto solo desarrolla seis referencias distintas: [42] a [47].

El principio

Cuanto más seguros son los sistemas, menos usables resultan. Y al revés: los sistemas más usables serán menos seguros.

Esta sección se pregunta cómo cerrar esa brecha desde el lado de quien construye el software, no de quien lo usa.

Los seis estudios desarrollados

42 Flechais y Sasse

Diseño participativo de seguridad en plataformas de e-ciencia

43 Alsharnouby et al.

Por qué el phishing sigue funcionando: estrategias del usuario

44 Roth et al.

Correo electrónico seguro no intrusivo, con cifrado transparente

45 Gorski et al.

Información de seguridad dentro de la documentación de APIs

46 Dhillon et al.

Objetivos basados en valores para equilibrar seguridad y usabilidad

47 Alemerien

Patrones de GUI para sitios de redes sociales

Estrategias y mecanismos (1 de 2)

01 Ubicar la seguridad donde se mira

Incluir información de seguridad en la documentación de APIs, y colocarla junto al código funcional en forma de comentarios.

02 De "orientado al código" a "orientado a conceptos"

No pelear contra el hábito del desarrollador, sino aprovecharlo. El principio aplica a cualquier herramienta de desarrollo.

03 Content Security Policy (CSP)

Política del navegador que define qué puede ejecutarse (scripts, estilos, iframes, conexiones) para reducir la superficie de ataque.

04 Patrones de GUI centrados en seguridad

Modelos de interfaz que dan retroalimentación adecuada para que el usuario decida sobre su privacidad sin fricción.

Estrategias y mecanismos (2 de 2)

05 Interfaces claras contra el phishing

Ayudan a identificar sitios y correos fraudulentos, pero no son determinantes si el usuario no recibió capacitación previa.

06 Correo seguro no intrusivo

Cifrado automático y transparente. Evita infraestructuras de clave pública y separa el intercambio de claves de su vinculación a identidades.

07 Diseño participativo con las partes interesadas

Mecanismo organizativo: involucrar a los stakeholders identifica necesidades reales y eleva la concienciación.

08 Conceptos abstractos en criterios medibles

Cuatro objetivos finales: facilidad de uso, comunicación del sistema, estandarización e integración, y capacidad del sistema.

Transversal: todos coinciden en que falta una metodología común que permita replicar los estudios.

¿Quiénes son los usuarios involucrados?

Desarrolladores

- Grupo heterogéneo: web, navegadores, sistemas, correo, ámbito académico.
- Experiencia dispar; Gorski et al. trabajó con 49 desarrolladores noveles.
- Usan estrategias orientadas al código: ignoran descripciones y van al ejemplo.
- Descartan la seguridad sin indicaciones claras: borran el fragmento conflictivo.
- Perciben la usabilidad como secundaria frente a la seguridad.
- Se motivan cuando se les asignan responsabilidades concretas.

Usuarios finales

- Interés genuino en proteger su información personal.
- Priorizan satisfacción, facilidad de aprendizaje y simplicidad de uso.
- Ciegos a amenazas técnicas sutiles: URLs incorrectas, direcciones IP falsas.
- Pero distinguen bien lo legítimo de lo fraudulento cuando el contexto es evidente.
- Prefieren soluciones simples, automáticas y no intrusivas.
- Rechazan pasos extra que interrumpen su tarea principal.

PREGUNTA 3

Parámetros de medición

Cada estudio definió sus propias métricas. Esa dispersión es, en sí misma, un hallazgo.

45	Gorski et al.	Éxito en 4 tareas de programación · seguimiento ocular · código funcional Y protegido con CSP · grupo de control con documentación de Google
47	Alemerien	4 tareas de red social · satisfacción, facilidad de aprendizaje, actitudes, interactividad y privacidad · escala Likert 1-5
43	Alsharnouby et al.	Porcentaje de aciertos por tipo de amenaza (7 tipos) · movimientos oculares · razonamiento verbalizado
44	Roth et al.	Sin métricas cuantitativas: 19 entrevistas evaluadas contra principios de diseño y "seguridad por interacción"
42	Flechais y Sasse	Cualitativo: transcripciones de 4 casos codificadas con ATLAS.ti en motivación, responsabilidad, comunicación y partes interesadas
46	Dhillon et al.	Entrevistas y análisis estadístico para reducir objetivos abstractos a 4 criterios evaluables

Resultado clave: la ubicación importa

Grupo de control

Documentación original de Google, sin información de ciberseguridad.

0 %

de las soluciones quedó protegida. Resolvieron el conflicto eliminando el fragmento de código problemático.

Grupos con CSP en el código

Sugerencias de seguridad como comentarios junto al ejemplo funcional.

Mayoría

de las soluciones resultó operativa y segura a la vez: hicieron funcionar la parte conflictiva en lugar de borrarla.

"Dejemos la seguridad de lado por ahora" — participante del grupo de control.

Resultado clave: el usuario no ve lo técnico

38 %

detectó la dirección IP en la URL de PayPal

38 %

cayó ante ventanas emergentes que pedían credenciales

62 %

reconoció el Chrome falso y el pop-up superpuesto

95 %

identificó el fraude evidente por contexto

Lectura

Los usuarios distinguen bien lo "normal" de lo "sospechoso" por contexto, pero son prácticamente ciegos a los indicadores técnicos. La interfaz ayuda; la capacitación es la que decide.

Los demás resultados

47 **Alemerien**

En las cuatro tareas los participantes prefirieron las interfaces propuestas sobre las de Facebook, que resultaron más complejas y con menos opciones de seguridad.

44 **Roth et al.**

Cuestionan que los usuarios privados necesiten infraestructuras de certificación. Dejan abiertas tres líneas: verificación de claves usable, métricas de seguridad por interacción e incentivos en la interfaz.

42 **Flechais y Sasse**

Involucrar a las partes interesadas identifica necesidades reales y eleva la concienciación. Asignar responsabilidades aumenta notablemente la motivación.

46 **Dhillon et al.**

Cuatro objetivos finales que orientan la implementación: facilidad de uso, comunicación del sistema, estandarización e integración, y capacidad del sistema.

Áreas de oportunidad

Falta de metodología común

Sin ella no se pueden replicar los estudios ni estandarizar el enfoque. Es el problema central de la sección.

Recomendaciones sin respaldo empírico

Muchas conclusiones son reflexiones organizativas más que directrices de diseño derivadas de datos.

Se confunde facilidad de uso con usabilidad

Se pide "simplificar el diseño" sin definir qué significa. El desarrollador necesita indicaciones accionables.

Hallazgo de Gorski subaprovechado

Se probó solo en APIs, pero el principio aplica a cualquier herramienta de desarrollo.

La capacitación queda fuera del diseño

Ningún estudio del grupo aborda la formación previa, aunque los datos de phishing muestran que es decisiva.

Sin requisitos de seguridad usable

Su ausencia en los contextos de desarrollo desincentiva las buenas prácticas desde etapas tempranas.

EN UNA FRASE

La seguridad usable no se gana escribiendo mejor documentación, sino poniéndola donde el desarrollador ya está mirando.

Y aun así, el campo sigue sin una metodología común que permita comparar lo que cada estudio encuentra.